

CHAPTER 6: DATABASE AUDIT

Le Thi Bao Thu

Faculty of Computer Science & Engineering

HCMC University of Technology

thule@hcmut.edu.vn

Outline

1 Introduction to database audit

2 Database audit methods

Auditing overview

- ❑ Audit: examines the documentation that reflects the actions, practices, and conduct of a business or individual.

- ❑ Audit measures:
 - compliance to policies
 - Procedures
 - Processes, and law

Audit term

- ❑ Audit/auditing: process of examining and validating documents, data, processes, procedures, systems
- ❑ Audit log: document that contains all activities that are being audited ordered in a chronological manner
- ❑ Audit objectives: set of business rules, system controls, government regulations, or security policies
- ❑ Auditor: a person authorized to audit

Audit term

- ❑ Audit procedure: set of instructions for the auditing process
- ❑ Audit report: a document that contains the audit findings
- ❑ Audit trail: chronological record of document changes, data changes, system activities, or operational events
- ❑ Data audit: chronological record of data changes stored in log file or database table object
- ❑ **Database auditing**: chronological record of database activities.

Database audit

- ❑ Database auditing is the monitoring and recording of selected user database actions.
- ❑ It can be based on:
 - individual actions, such as the type of SQL statement executed
 - combinations of factors that can include user name, application, time...
- ❑ Audit = Who did what to which data when and how.

Why is database audit important?

- ❑ Enable future accountability for current actions taken in a particular schema, table, or row, or affecting specific content
- ❑ Investigate suspicious activity.
 - For example, if some user is deleting data from tables, the security administrator might decide to audit all connections to the database and all successful and unsuccessful deletions of rows from all tables in the database.
- ❑ Notify an auditor that an unauthorized user is manipulating or deleting data and that the user has more privileges than expected, which can lead to reassessing user authorizations.
- ❑ Monitor and gather data about specific database activities.
- ❑ Detect problems with an authorization or access control implementation

Audit classifications

Internal audit

- ❑ Conducted by a staff member **of the company** being audited
- ❑ Purpose:
 - Verify that all auditing objectives are met
 - Investigate a situation prompted by an internal event or incident
 - Investigate a situation prompted by an external request

External audit

- ❑ Conducted by a **party outside the company** that is being audited
- ❑ Purpose:
 - Investigate the financial or operational state of the company
 - Verify that all auditing objectives are met

Audit classifications

- ❑ Automatic audit:
 - Prompted and performed automatically (without human intervention)
 - Used mainly for systems and database systems
 - Administrators read and interpret reports; inference engine or artificial intelligence

- ❑ Manual audit: performed completely by humans

- ❑ Hybrid audit

Audit types

- ❑ Financial audit: ensures that all financial transactions are accounted for and comply with the law
- ❑ Security audit: evaluates if the system is secure
- ❑ Compliance audit: system complies with industry standards, government regulations, or partner and client policies
- ❑ Operational audit: Verifies if an operation is working according to the policies of the company.
- ❑ Investigative audit: performed in response to an event, request, threat, or incident to verify the integrity of the system.
- ❑ Product audit: performed to ensure that the product complies with industry standards.
- ❑ Preventive audit: Performed to identify problems before they occur

Compliances audit

- ❑ A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines.
- ❑ Well-known compliance audits include:
 - HIPAA (Health Insurance Portability and Accountability Act)
 - SOX (Sarbanes-Oxley Act)
 - GLBA (Gramm-Leach-Bliley Act)
 - PCI DSS (Payment Card Industry Data Security Standard)
 - SOC 2: developed by the American Institute of CPAs (AICPA)

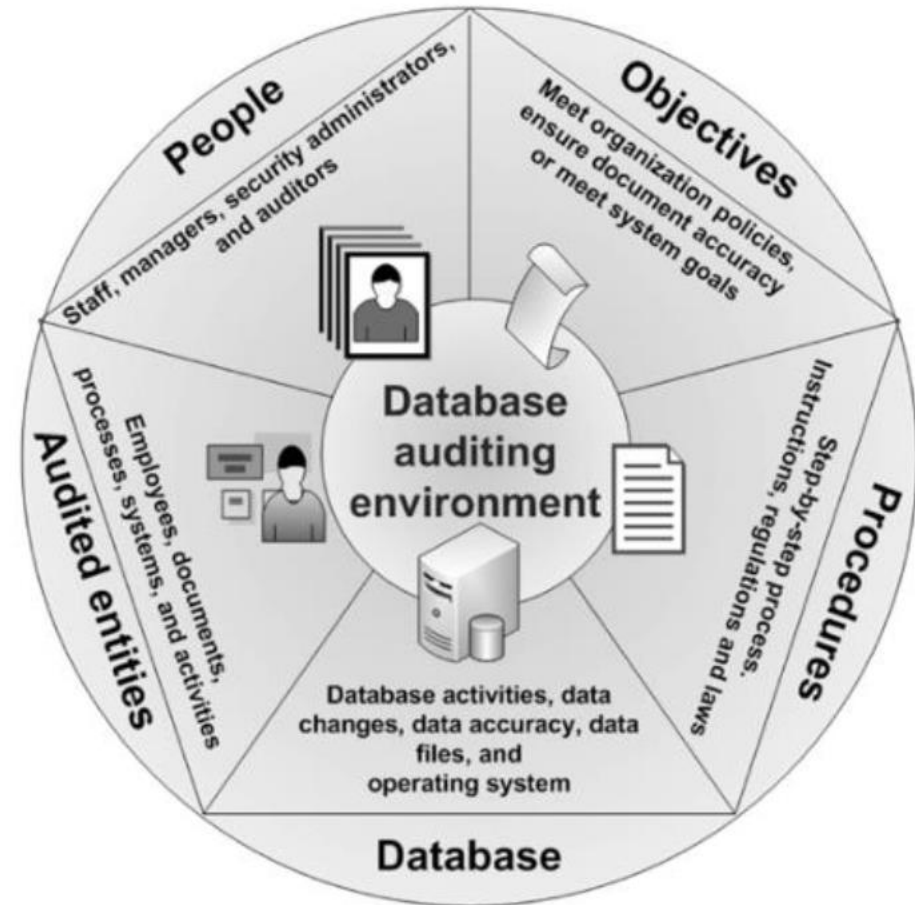
Audit activities

- ❑ Some auditing activities relating to Section 404 of the Sarbanes-Oxley:
 - Privileged user activity
 - Logins and logouts
 - Application and data trigger modifications
 - Changes to user definitions and privileges
 - Data structure changes
 - Read and write access to sensitive data
 - Errors and exceptions
 - Sources of data access activity—host names, user IDs, IP addresses, and port numbers
 - Time, program name, accessed data size, data access command, and other parameters for each data access transaction

Audit process



Audit environment



Side Effects of Audit

- ❑ Performance problems
- ❑ Too many reports and documents
- ❑ Disruption to the operations of the audited entity
- ❑ Consumption of resources, and added costs from downtime
- ❑ Friction between operators and auditor

Outline

1 Introduction to database audit

2 Database audit methods

Database audit requirements

- ❑ The ability to independently monitor and audit all database activity, including administrator.
- ❑ The ability to store this activity securely outside the database.
- ❑ The ability to aggregate and correlate activity from multiple heterogeneous DBMSs.
- ❑ The ability to enforce separation of duties on database administrators
- ❑ Auditing must include monitoring of DBA activity, and should prevent DBA manipulation or tampering with logs or recorded activity.
- ❑ The ability to generate alerts on policy violations.

Database audit techniques

- ☐ Application server logs
- ☐ Application audit
- ☐ Trigger auditing
- ☐ Command auditing

Auditing categories

❑ Audit logon/logoff into the database

- At least: login name, timestamp
- Additional information: TCP/IP address of the client initiating the connection, program used to initiate the connection
- All failed login attempts
 - The username
 - The client IP from which connections are failing
 - Source program
 - Time of day

❑ Audit sources of database usage:

- network node is connected to the database (e.g., using an IP address or a host name)
- application is being used to access the database

Auditing categories

- ❑ Audit database usage outside normal operating hours.
- ❑ Audit Data Definition Language - DDL activity
 - One of the most implemented audit trails
 - DDL commands are potentially the most damaging commands that exist and can certainly be used by an attacker to compromise any system.
 - There are three main methods:
 - Use database audit features
 - Use an external auditing system
 - Compare schema snapshots

Auditing categories

- ❑ Audit database errors
 - Failed logins
 - SQL injection
 - Failed attempt to elevate privileges
- ❑ Audit changes to sources of stored procedures and triggers
- ❑ Audit changes to privileges, user/login definitions, and other security attributes
 - Must-have for database auditing
 - Addition and deletion of users, logins, and roles
 - Changes to the mappings between logins and users/roles
 - Privilege changes—whether by user or role Password change
 - Changes to security attributes at a server, database, statement, or object level

Auditing categories

- ❑ Audit creations, changes, and usage of database links and of replication.
- ❑ Audit changes to sensitive data
 - .Data change audit trails are common in almost all major auditing initiatives.
 - should selectively choose which objects and which commands to audit.
- ❑ Audit any changes made to the definition of what to audit

Outline

-
- 1 Introduction to database audit
 - 2 Database audit methods

